

— Active Directory — מודול 13 תרגול

חומר לימוד

1 יחידות

תוכן העניינים

1. 🧠 תרגול — מודול 13: Active Directory

חלק א' — שאלות תרגול

Q1. מהו Domain Controller, ולמה הוא היעד המרכזי בבדיקת AD?

Q2. מהו SPN, ואיך הוא קשור ל-Kerberoasting?

Q3. איך עובד LLMNR Poisoning, ולמה הוא נקודת כניסה קלאסית?

Q4. מה ההבדל בין Kerberoasting ל-AS-REP Roasting?

Q5. מהו Pass-the-Hash, ולמה לא צריך לפצח את הסיסמה?

Q6. מה עושה BloodHound, ולמה הוא כה חשוב?

Q7. מהו DCSync, ומהו Golden Ticket?

Q8. אילו קודי hashcat משמשים ל-TGS, NTLMv2 ו-AS-REP?

תשובות

- השרת שמריץ AD ומאמת כל התחברות; שליטה עליו = שליטה בכל המשתמשים והמחשבים.
- Service Principal Name — מזהה חשבון שירות; **כל** משתמש דומיין יכול לבקש את ה-TGS שלו ולפצח (Kerberoasting) offline.
- מחשב מחפש שם שלא ב-DNS ו"צועק" ב-LLMNR/NBT-NS; התוקף עונה "אני" והקורבן שולח NTLMv2 hash. לרוב עובד **ללא אישורים**.
- TGS = Kerberoasting של חשבונות **שירות** (דורש אישורי משתמש); AS-REP = חשבונות **ללא preauth** (לא דורש אישורים, רק שמות).
- שימוש ב-NTLM hash כמות שהוא לאימות; NTLM מאמת מול ה-hash ולא מול הסיסמה הגולמית.
- אוסף את כל יחסי ה-AD ומצייר גרף עם "הנתיב הקצר ביותר ל-Domain Admin"; הופך ניחוש לניתוח מדויק.
- DCSync** — מדמה DC ומבקש שכפול של מסד הסיסמאות (כולל krbtgt/Administrator). **Golden Ticket** — TGT מזויף עם hash של krbtgt → גישה נצחית לכל שירות.

8. NTLMv2 = 5600, TGS (Kerberoast) = 13100, AS-REP = 18200.

חלק ב' — תרחיש מהחיים האמיתי

“בדיקה פנימית ביום הראשון” 🏢

התחלת בדיקת חדירה פנימית בחברה. חיברו אותך לרשת ה-LAN עם מחשב נייד בלבד — ללא שום אישורים. המטרה: Domain Admin.

```
09:00 responder -I eth0 -dwv → 'אחרי 20 דק', NTLMv2 של "m.levi"
09:30 hashcat -m 5600 → "Welcome2023!"
10:00 crackmapexec smb <dc> -u m.levi -p 'Welcome2023!' → תקף!
10:15 GetUserSPNs -request → TGS של "svc_backup"
10:45 hashcat -m 13100 → "Backup#2020"
11:00 bloodhound-python -c All → svc_backup הוא AdminTo על SRV-FILE
11:30 secretsdump על SRV-FILE → NTLM של "admin_dom" (Domain Admin!)
12:00 secretsdump DCSync → hash של Administrator → 🏆
```

המשימה: 1. מדוע הצליחה התקיפה בלי שהיו לך אישורים בהתחלה? מה איפשר את הצעד הראשון? 2. באיזה שלב BloodHound “קיצר לך דרך”? מה הוא חשף? 3. כתוב שלוש המלצות תיקון שהיו שוברות את השרשרת בנקודות שונות.

פתרון מנחה 💡

1. **LLMNR/NBT-NS Poisoning** — הפרוטוקולים האלה משדרים ברשת כברירת מחדל; Responder לכד hash מבלי שנדרשו אישורים כלל.
2. BloodHound חשף ש-svc_backup הוא AdminTo על SRV-FILE, ושם ישב session של Domain Admin — קיצור דרך מ"חשבון שירות" ל"נתיב ל-DA" שלא היינו מגלים ידנית.
3. (א) **כבה LLMNR/NBT-NS** → אין צעד ראשון; (ב) **סיסמאות חזקות/gMSA לחשבונות שירות** → Kerberoasting נכשל; (ג) **least-privilege + אל תשאיר sessions של DA על שרתים רגילים** → BloodHound לא מוצא נתיב.

🎯 זהו בדיוק מהלך של בדיקה פנימית אמיתית: מ"כבל רשת" ל-Domain Admin תוך שעות. ההגנה היא שכבות — כל תיקון שובר חוליה אחרת בשרשרת.

← חזרה למודול · תרגילים מעשיים